



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-47294 Microsoft SharePoint Server Remote Code Execution Vulnerability

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-11
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-47294 Microsoft SharePoint Server Remote Code Execution Vulnerability - Vulnerability Report

Published: 2026-06-11 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

CVE-2026-47294 is a high-severity Microsoft SharePoint Server remote code execution vulnerability affecting SharePoint Enterprise Server 2016, SharePoint Server 2019, and SharePoint Server Subscription Edition. Microsoft, the CVE Program CNA record, and NVD align that the flaw is an unsafe deserialization / OS command injection issue (CWE-78) that can allow an authorized attacker to execute code over a network. The current public record assigns CVSS v3.1 base score 8.0 and rates the issue Important.

For most organizations, the practical risk is concentrated on internet-facing or broadly reachable SharePoint farms that host collaboration sites with delegated content administration. Microsoft's FAQ language indicates the attacker must already be authenticated and, in one scenario, at least a SharePoint Site Owner. That requirement materially lowers indiscriminate unauthenticated internet-worm risk, but it still leaves meaningful exposure for environments with compromised user accounts, over-privileged SharePoint owners, weak external publishing controls, or hybrid identity estates where attackers can gain authenticated footholds.

The intake event that triggered this report was a 2026-06-10 acknowledgement-only update in the Microsoft Security Update Guide, not a newly announced exploitation campaign. Even so, the underlying vulnerability remains operationally important because successful exploitation can produce full confidentiality, integrity, and availability impact on the affected SharePoint server. Microsoft states the issue was not publicly disclosed and not exploited at release, and CISA's reviewed KEV feed did not list the CVE as of 2026-06-11. Defensive priority should therefore center on rapid patch validation, SharePoint privilege review, and behavior-based hunting for suspicious command execution or web-tier abuse on exposed farms.

Executive takeaway	Assessment
Business impact	Successful exploitation can yield server-side remote code execution on enterprise SharePoint infrastructure, creating risk of content theft, server compromise, and follow-on lateral movement.
Attacker requirement	Authenticated attacker; Microsoft FAQ text indicates at least Site Owner privileges in one described path.
Public exploitation status	No reviewed authoritative source confirmed in-the-wild exploitation as of 2026-06-11.
Immediate priority	Apply SharePoint security updates, reduce unnecessary Site Owner exposure, and monitor SharePoint servers for suspicious child-process execution and outbound connections.

2. Intelligence Requirement

This review addresses the following intelligence requirement: what does the public record currently say about `CVE-2026-47294`, which SharePoint deployments are exposed, how credible is near-term exploitation risk, and what should defenders do immediately to reduce compromise opportunities?

Question	Assessment
What is the vulnerability?	A Microsoft SharePoint Server remote code execution vulnerability described as deserialization of untrusted data / OS command injection in Microsoft Office SharePoint.
Which products are affected?	Microsoft SharePoint Enterprise Server 2016, SharePoint Server 2019, and SharePoint Server Subscription Edition on x64 systems.
What access does the attacker need?	Authenticated network access; public Microsoft FAQ language indicates at least SharePoint Site Owner privileges in one exploitation scenario.

What is the impact?	High confidentiality, integrity, and availability impact (C:H/I:H/A:H) on the SharePoint server if exploitation succeeds.
Is exploitation publicly confirmed?	No. Microsoft states not publicly disclosed and not exploited at release; CISA KEV did not list the CVE in the reviewed snapshot.
What matters most to defenders?	Patch exposed farms, tighten SharePoint privilege boundaries, and hunt for suspicious server-side command execution and anomalous web activity on SharePoint hosts.

3. Source Review and Confidence

Source	Contribution	Confidence
Microsoft Security Update Guide entry	Canonical Microsoft advisory page and chronology for the 2026-06-10 acknowledgement-only update.	High
Microsoft May 2026 CVRF document and update mapping	Authoritative affected-product list, FAQ text, exploitability assessment, remediation KBs, fixed versions, and disclosure / exploitation flags.	High
CVE Program CNA record	Confirms affected versions, `CWE-78`, Microsoft-authored description, and CVSS v3.1 vector.	High
NVD JSON 2.0 record	Corroborates normalized CVE metadata and public analysis state.	High
CISA weekly bulletin and KEV feed snapshot	Confirms public-sector cataloging of the issue and time-bounded absence from KEV.	High
Rapid7 vulnerability database entry	Independent defender-oriented corroboration of the SharePoint RCE framing and severity.	Medium

Confidence is high on the existence of the vulnerability, the affected SharePoint product families, the remediation path, and the current lack of confirmed public exploitation because those facts are directly supported by Microsoft, the CNA record, NVD, and CISA. Confidence is lower on the exact exploitation chain because Microsoft's own FAQ text introduces some ambiguity: one FAQ frames the `UI:R` element as a client connecting to a malicious server, while another says an authenticated attacker who is at least a Site Owner can inject and execute code remotely on the SharePoint server. The public source set therefore supports confident defensive action, but not a precise single exploit narrative.

A second nuance worth preserving is that the intake item was triggered by an acknowledgement change on 2026-06-10 rather than a newly discovered campaign, proof of concept, or exploit-status reversal. That means the report should prioritize durable exposure management and realistic threat modeling over sensational exploitation claims.

4.1 Core Vulnerability Metadata

Field	Value
CVE	`CVE-2026-47294`
Vulnerability name	`Microsoft SharePoint Server Remote Code Execution Vulnerability`

Weakness	`CWE-78` Improper Neutralization of Special Elements used in an OS Command (`OS Command Injection`)
Alternate Microsoft description	Deserialization of untrusted data in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
Severity	`8.0 / HIGH` (CVSS v3.1)
CVSS v3.1 vector	`AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H`
Attack vector	Network
Privileges required	Low
User interaction	Required
Scope	Unchanged
Impact profile	High confidentiality, integrity, and availability impact
Microsoft severity label	Important
Public disclosure at release	No
Exploitation at release	No
Microsoft exploitability assessment	Exploitation Less Likely
CISA SSVC summary	`Exploitation: none`, `Automatable: no`, `Technical Impact: total`
Vendor public date in CNA record	2026-05-29
NVD publication date	2026-06-01
Intake update reviewed	2026-06-10 acknowledgement-only change

4.2 Affected Products and Remediation Matrix

Product family	Vulnerable versions	Fixed version	Microsoft remediation
SharePoint Enterprise Server 2016	`>= 16.0.0` and ` 16.0.5552.1002`	`16.0.5552.1002`	`KB5002868`
SharePoint Server 2019	`>= 16.0.0` and ` 16.0.10417.20128`	`16.0.10417.20128`	`KB5002870`
SharePoint Server Subscription Edition	`>= 16.0.0` and ` 16.0.19725.20280`	`16.0.19725.20280`	`KB5002863`

Microsoft's FAQ additionally clarifies that the SharePoint Enterprise Server 2016 update also applies to customers running SharePoint Server 2016. That matters operationally because many environments refer to legacy 2016 farms generically as "SharePoint 2016" even when the authoritative remediation package is labeled for the Enterprise Server 2016 line.

4.3 Analyst Findings

Finding	Defensive implication
---------	-----------------------

The vulnerability allows server-side code execution with total-impact semantics, but it is not described as unauthenticated or automatically wormable.	Prioritize farms where attackers could realistically obtain or abuse authenticated SharePoint permissions rather than assuming only anonymous web exposure matters.
Microsoft FAQ language ties one exploitation path to a user or client interaction requirement and another to authenticated Site Owner capability.	Detection logic should avoid overfitting to a single exploit chain and instead monitor for post-access abuse patterns on SharePoint servers.
The highest-risk environments are exposed collaboration farms with delegated site administration, external sharing, or weak privilege hygiene.	Review Site Owner sprawl, stale privileged accounts, and externally reachable publishing surfaces alongside patch deployment.
No reviewed source provided public IOCs, exploit packets, or a stable exploit artifact.	Hunting should focus on suspicious child processes, anomalous outbound connections, file creation in SharePoint web roots, and privileged SharePoint account activity.
The 2026-06-10 feed event was informational, not an exploit-status escalation.	Reprioritization should be evidence-based; patch urgency remains high because the impact is severe, not because the feed item itself proved new adversary activity.

5. Threat Context

CVE-2026-47294 is best understood as an authenticated application-tier compromise risk for on-premises SharePoint rather than a mass unauthenticated internet spray condition. SharePoint routinely sits at the intersection of document storage, business workflows, search, identity federation, and intranet publishing. A vulnerability that enables server-side remote code execution in that tier can expose high-value documents, harvest credentials or tokens available to the application context, create persistence on the SharePoint host, and enable follow-on movement into adjacent Windows infrastructure.

The threat model is especially concerning where SharePoint is internet-facing, federated to external identities, or administered by large populations of business users with elevated site privileges. In those environments, a compromised contractor account, phishing-derived session, or stale privileged collaboration account may be enough to satisfy the authenticated prerequisite. Even if exploitation is assessed as less likely by Microsoft, the blast radius of a successful SharePoint compromise can be substantial because the server often has privileged access to backend SQL, file stores, service accounts, or internal business content.

No reviewed authoritative source tied the CVE to a named threat actor, malware campaign, proof-of-concept exploit release, or KEV inclusion as of 2026-06-11. That absence should be treated as negative evidence for current mass exploitation, not as a reason to delay remediation on exposed farms. The practical defender stance is to assume that a severe SharePoint RCE with a realistic authenticated path is attractive to both opportunistic post-phishing operators and targeted actors seeking document access or application-tier footholds.

MITRE ATT&CK mapping	Relevance	Confidence
`T1190` Exploit Public-Facing Application	Best-fit ATT&CK mapping where affected SharePoint servers are internet-facing or broadly reachable and the exploit path is exercised against the SharePoint application tier.	Medium
`T1078` Valid Accounts	Microsoft indicates the attacker must be authenticated and, in one FAQ, at least a Site Owner, making legitimate-but-abused credentials a plausible prerequisite.	Medium
Additional ATT&CK techniques	Not assigned with high confidence from the reviewed public record because no public exploit chain or post-exploitation tradecraft	High

	was authoritatively described.	
--	--------------------------------	--

6. Detection and Hunting

Because the public source set does not currently provide exploit-specific IOCs or a deterministic packet signature, the most defensible monitoring approach is layered: identify vulnerable SharePoint farms, detect suspicious server-side command execution, hunt for anomalous outbound connections or web-root file changes, and review privileged SharePoint account activity around the exposure window.

6.1 Detection Logic Summary

Signal	Telemetry source	Analytic goal
SharePoint hosts below Microsoft fixed versions	CMDB, vulnerability scanner output, EDR device inventory, SharePoint farm inventory	Identify exposure and prioritize patching
`w3wp.exe`, `OWSTIMER.EXE`, or `noderunner.exe` spawning script or shell interpreters	EDR process telemetry, Sysmon Event ID 1, Windows 4688	Detect likely post-exploitation command execution from SharePoint server processes
Public outbound network connections from SharePoint worker processes or spawned shells	EDR network telemetry, firewall logs, proxy logs	Surface potential payload retrieval, beaconing, or post-exploitation staging
New `.aspx`, `.ashx`, `.ps1`, or batch files in SharePoint web roots or extension directories	EDR file telemetry, Sysmon file-create events, FIM	Detect webshell-like persistence or suspicious server-side artifacts
Authentication or privilege events involving unusual SharePoint Site Owner activity preceding process execution	SharePoint audit logs, Entra ID / AD logs, IIS logs, SIEM correlation	Link credential abuse or over-privileged user activity to attempted exploitation

Analyst caveat: the public source set supports behavior-driven hunts, not exploit confirmation. High-signal results should be triaged in context with approved SharePoint administrative jobs, scheduled workflows, third-party integrations, and patch activity windows.

6.2 Example Sigma Logic

```

title: Suspicious Child Process Spawned by SharePoint Worker Process
id: 01bcd6d6-4729-4294-86e1-sharepoint-rce
status: experimental
description: Detects suspicious command execution from common SharePoint worker processes that could merit investigation during CVE-2026-47294 response activity.
logsource:
  category: process_creation
  product: windows
detection:
  selection_parent:
    ParentImage|endswith:
      - '\\w3wp.exe'
      - '\\OWSTIMER.EXE'
      - '\\noderunner.exe'
  selection_child:
    Image|endswith:
      - '\\cmd.exe'
      - '\\powershell.exe'
      - '\\pwsh.exe'
      - '\\wscript.exe'
      - '\\cscript.exe'
      - '\\mshta.exe'

```

```

- '\\rundll32.exe'
- '\\certutil.exe'
- '\\bitsadmin.exe'
condition: selection_parent and selection_child
falsepositives:
- approved SharePoint administrative automation
- patching or third-party integration jobs that legitimately spawn child processes
level: high

```

6.3 Example Hunt Queries

SharePoint web-tier suspicious child-process hunt (Microsoft Defender XDR / Sentinel advanced hunting):

```

DeviceProcessEvents
| where Timestamp > ago(30d)
| where FolderPath has_any ("\\Inetpub\\", "\\Program Files\\Common Files\\microsoft shared\\Web Server Extensions")
| where InitiatingProcessFolderPath has_any ("\\Inetpub\\", "\\Program Files\\Common Files\\microsoft shared\\Web Server Extensions")
| where InitiatingProcessFileName in~ ("w3wp.exe", "OWSTIMER.EXE", "noderunner.exe")
| where FileName in~ ("cmd.exe", "powershell.exe", "pwsh.exe", "wscript.exe", "cscript.exe", "mshta.exe", "rundll32.exe", "certutil.exe", "bitsadmin.exe")
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName, InitiatingProcessCommandLine, FileName, ProcessCommandLine, SHA1
| order by Timestamp desc

```

Suspicious outbound connections from SharePoint worker processes or likely child payloads:

```

DeviceNetworkEvents
| where Timestamp > ago(30d)
| where InitiatingProcessFileName in~ ("w3wp.exe", "OWSTIMER.EXE", "noderunner.exe", "powershell.exe", "cmd.exe")
| where RemoteIPType == "Public"
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, RemoteIP, RemotePort, RemoteUrl
| order by Timestamp desc

```

Web-root or extension-path file creation hunt:

```

DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has_any ("\\Inetpub\\wwwroot\\", "\\Program Files\\Common Files\\microsoft shared\\Web Server Extensions")
| where FileName endswith ".aspx" or FileName endswith ".ashx" or FileName endswith ".ps1" or FileName endswith ".bat"
| project Timestamp, DeviceName, ActionType, FolderPath, FileName, SHA1, InitiatingProcessFileName, InitiatingProcessCommandLine
| order by Timestamp desc

```

Splunk process-correlation example:

```

index=edr OR index=wineventlog
(host_tag=sharepoint OR host IN ("sharepoint*"))
(Image="*\\cmd.exe" OR Image="*\\powershell.exe" OR Image="*\\pwsh.exe" OR Image="*\\wscript.exe" OR Image="*\\cscript.exe" OR Image="*\\mshta.exe" OR Image="*\\rundll32.exe")
(ParentImage="*\\w3wp.exe" OR ParentImage="*\\OWSTIMER.EXE" OR ParentImage="*\\noderunner.exe")
| stats count min(_time) as firstTime max(_time) as lastTime values(CommandLine) as commandLine values(ParentCommandLine) as parentCommandLine by host user ParentImage Image
| convert ctime(firstTime) ctime(lastTime)
| sort - lastTime

```

6.4 Hunting Guidance

Hunt question	Why it matters
Which SharePoint farms remained below the fixed versions after 2026-05-29 / 2026-06-01?	Those systems form the highest-priority retrospective review set.
Did any SharePoint worker process launch scripting engines or	That pattern is a practical proxy for successful server-side

shell utilities shortly before suspicious outbound connections?	command execution.
Were new ASPX or handler files created under SharePoint web roots, layouts paths, or temporary deployment locations?	These artifacts may indicate persistence, webshell staging, or malicious administrative code injection.
Did unusual Site Owner activity, account sign-ins, or IIS requests precede process execution on exposed SharePoint servers?	The public exploit model requires authentication, making abused privileged collaboration identities especially relevant.
Were suspicious events dismissed as routine patching, search indexing, or workflow automation without process-lineage review?	SharePoint's operational noise can mask malicious activity if analysts do not anchor triage in parent/child process relationships.

7. Recommendations

Priority	Owner	Action
Critical	SharePoint Platform Owners	Apply Microsoft remediation immediately: `KB5002868` for SharePoint Enterprise Server 2016 / SharePoint Server 2016, `KB5002870` for SharePoint Server 2019, and `KB5002863` for SharePoint Server Subscription Edition.
Critical	Infrastructure / Vulnerability Management	Verify remediation by installed KB and fixed build number, not by a generic patch-compliant status flag alone.
Critical	Identity and Collaboration Admins	Review and reduce unnecessary SharePoint Site Owner privileges, stale external collaboration accounts, and inherited administrative access on high-value farms.
High	Network / Application Security	Minimize unnecessary internet exposure for on-premises SharePoint, enforce reverse-proxy or WAF controls where required, and limit admin interfaces to trusted networks.
High	SOC / Detection Engineering	Deploy temporary monitoring for suspicious child processes from SharePoint worker services, public outbound connections from SharePoint hosts, and new script/web-content files in SharePoint directories.
High	Incident Response	Review SharePoint and EDR telemetry back to at least 2026-05-29 for exposed farms, especially where privileged content owners or external identities had unusual activity.
Medium	SharePoint Operations	Baseline legitimate scheduled jobs, workflow engines, and third-party integrations that may spawn processes so analysts can separate expected automation from suspicious execution.
Medium	Threat Intelligence	Recheck Microsoft, CISA KEV, and defender reporting across subsequent patch cycles for exploit-status changes, proof-of-

		concept release, or campaign attribution.
--	--	---

Additional analyst guidance:

- Treat the lack of confirmed public exploitation as a calibration input, not as a justification to defer patching on exposed or business-critical SharePoint systems.
- If immediate patching is not possible, pair the exception with compensating controls: tighten privileged account access, increase log retention on SharePoint hosts, and add focused alerting around worker-process child execution and suspicious file creation.
- In environments with limited SharePoint-specific telemetry, exposure reduction and privilege cleanup will usually produce more risk reduction than attempting to build an overconfident exploit signature from sparse public evidence.

8. References

- 1. Microsoft Security Update Guide, CVE-2026-47294:
<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-47294>
- 2. Microsoft CVRF OData update mapping for CVE-2026-47294:
<https://api.msrc.microsoft.com/cvrf/v3.0/updates/CVE-2026-47294>
- 3. Microsoft May 2026 CVRF document: <https://api.msrc.microsoft.com/cvrf/v3.0/cvrf/2026-May>
- 4. CVE Program CNA API record: <https://cveawg.mitre.org/api/cve/CVE-2026-47294>
- 5. NVD JSON 2.0 API query: <https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-47294>
- 6. CISA Vulnerability Summary for the Week of June 1, 2026: <https://www.cisa.gov/news-events/bulletins/sb26-159>
- 7. CISA Known Exploited Vulnerabilities JSON feed:
https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
- 8. Rapid7 vulnerability database entry: <https://www.rapid7.com/db/vulnerabilities/microsoft-sharepoint-cve-2026-47294/>